

Narrativa explicativa GQM + PRAGMATIC

Cuando los indicadores TIBER aprenden a justificarse

1. Del “medimos porque podemos” al “medimos porque hace falta”

En ciberseguridad es fácil acumular indicadores: logs, alertas, dashboards, gráficas de colores. Más difícil es demostrar que esos indicadores:

- Responden a objetivos claros.
- Tienen valor para la dirección y el regulador.
- No se convierten en ruido visual.

El enfoque GQM + PRAGMATIC propuesto busca precisamente eso: que cada métrica relacionada con TIBER-EU / TIBER-ES pueda responder a tres preguntas incómodas:

1. ¿Para qué existe? (Goal)
2. ¿Qué pregunta concreta ayuda a responder? (Question)
3. ¿Por qué es una buena métrica y no una distracción? (PRAGMATIC)

2. GQM: darle un propósito a cada cifra

GQM obliga a conectar:

- Metas de alto nivel (por ejemplo, “mejorar la resiliencia de las funciones críticas”).
- Preguntas operativas (“¿cuántas CIFs han sido realmente sometidas a pruebas TIBER?”).
- Métricas específicas (el porcentaje de CIFs cubiertas).

Esto tiene varias ventajas:

- Facilita explicar a la alta dirección por qué se piden determinados datos.
- Permite detectar métricas redundantes o puramente decorativas.
- Ayuda a diseñar encuestas y cuadros de mando que no se convierten en colecciones de curiosidades.

3. PRAGMATIC: nueve filtros para métricas con derecho a existir

No basta con que una métrica responda a una pregunta; debe hacerlo bien.

Los nueve criterios PRAGMATIC son un pequeño comité de ética para indicadores:

- Predictivo: ¿dice algo sobre el futuro, no solo sobre el pasado?
- Relevante: ¿importa realmente para TIBER/DORA, o solo es “bonita”?
- Accionable: si empeora, ¿sabemos qué hacer?
- Genuino: ¿mide lo que creemos que mide, o es un proxy engañoso?
- Significativo: ¿su variación importa, o se mueve por ruido?
- Preciso: ¿podemos medirla sin discusiones metafísicas?
- Oportuna: ¿la tendremos a tiempo para decidir?
- Independiente: ¿es resistente a la manipulación interesada?
- Rentable: ¿justifica el coste de recogerla?

La matriz PRAGMATIC asigna una puntuación 0–5 a cada métrica en estos ejes, y eso permite priorizar sin discusiones interminables.

4. Cómo encaja esto con TIBER-EU / TIBER-ES

TIBER no nació pensando en dashboards nacionales, sino en ejercicios concretos de red teaming basados en inteligencia de amenazas. Sin embargo:

- Define procesos, entregables y resultados que se prestan a ser medidos.
- Se ha alineado con DORA/TLPT, que sí piensa en supervisión comparativa.

El marco GQM + PRAGMATIC:

- Traduce los objetivos implícitos de TIBER (probar CIFs, mejorar detección y respuesta, cerrar brechas) en metas GQM.
- Deriva de los entregables TIBER (TTIR, RTTR, BTTR, planes de acción) métricas concretas.
- Filtra esas métricas con PRAGMATIC para quedarse con las que aportan valor real.

5. Beneficios para entidades, reguladores y, de paso, para el CISO

Para las **entidades**, el enfoque permite:

- Priorizar qué métricas merece la pena integrar en sus cuadros internos.
- Defender ante auditoría y reguladores por qué monitorizan unas cosas y no otras.
- Evitar la “fábrica de KPIs” que consume recursos sin mejorar la resiliencia.

Para los **reguladores**, ofrece:

- Una base argumental para indicadores nacionales y requisitos de reporte.
- Un lenguaje común para hablar con entidades de madurez, sin improvisar en cada inspección.

Y para el **CISO**:

- Una herramienta para convertir TIBER en palanca estratégica, no en mero trámite.
- Un argumento sólido cuando alguien quiera añadir “un KPI más” porque queda bien en la presentación.

6. Cómo utilizar esta narrativa

Esta narrativa puede acompañar:

- La difusión del marco entre entidades y supervisores.
- La introducción de la encuesta GQM/PRAGMATIC en foros sectoriales.
- Las primeras diapositivas del informe ejecutivo de resultados.

Si al leerla alguien se reconoce en la frase “medimos porque podemos”, habrá merecido la pena: es el primer paso para pasar a “medimos porque nos ayuda a decidir”.

Fin de la Narrativa GQM + PRAGMATIC.